Arquitetura de Segurança

Objetivo

A arquitetura de segurança da OrbiVet tem como objetivo proteger os dados pessoais, as contas, as informações dos animais e os registros de clínicas veterinárias, pet shops e demais prestadores de serviços, impedindo acessos indevidos e garantindo que cada usuário visualize e altere somente as informações permitidas para sua função.

Princípios de Segurança

A arquitetura será orientada pelos seguintes princípios:

- Confidencialidade: impedir que pessoas sem autorização consultem dados pessoais, informações de saúde dos animais ou registros privados.
- Integridade: impedir alterações, exclusões ou modificações indevidas nos dados dos usuários, animais, agendamentos e históricos.
- Disponibilidade: manter os dados e as funcionalidades acessíveis quando necessários, utilizando backups e mecanismos de recuperação.
- Privilégio mínimo: conceder a cada usuário apenas as permissões necessárias para realizar suas atividades.
- Privacidade desde a concepção: coletar somente os dados necessários, explicar suas finalidades e limitar seu compartilhamento.
- Rastreabilidade: registrar operações administrativas sensíveis para identificar quem realizou cada ação e quando ela ocorreu.

Autenticação e Gerenciamento de Contas

O sistema deverá validar os dados de cadastro, impedir contas duplicadas pelo mesmo e-mail e proteger o login contra tentativas excessivas. As senhas serão armazenadas por meio de algoritmos seguros de hash, nunca em texto puro.

A recuperação de senha utilizará mecanismos temporários e de uso único. As sessões terão prazo de validade e poderão ser revogadas em situações de risco, como troca de senha ou comprometimento da conta. Por utilizar uma API REST stateless, o backend não dependerá de sessões mantidas apenas na memória de uma instância.

Autorização e Controle de Acesso por Perfil

O acesso será definido conforme o perfil do usuário e sua relação com o recurso solicitado.

Perfil	Permissões
Tutor	Gerenciar seus animais, históricos, medicamentos, alimentação, lembretes e alertas.
Veterinário / Profissional	Acessar informações necessárias ao cuidado dos animais autorizados e consultar informações compartilhadas para atendimentos autorizados.
Clínica / Pet Shop	Gerenciar serviços, horários, agendamentos e acessar dados necessários ao atendimento.
ONG / Organização	Gerenciar campanhas e ações de apoio animal autorizadas.
Administrador	Realizar atividades de administração, suporte e moderação com privilégios controlados.

Proteção das APIs e dos dados

A comunicação utilizará HTTPS, e as APIs deverão validar entradas, restringir requisições abusivas e impedir acessos indevidos por manipulação de identificadores. As mensagens de erro não deverão expor informações internas.

Os dados deverão ser coletados conforme a necessidade da plataforma, com transparência sobre suas finalidades e compartilhamentos. O sistema deverá permitir consulta, correção e solicitação de exclusão quando aplicável, respeitando as obrigações legais de retenção.

Nos alertas de animais perdidos, o tutor deverá visualizar e confirmar quais informações serão públicas. A localização residencial exata não será divulgada automaticamente.